Report di Penetration Testing e Privilege Escalation

> **Target:** Macchina Virtuale Ubuntu 12.04 (bsides2018)
> **Studente:** Simone Meola
> **Obiettivo:** Acquisizione dei privilegi di root e lettura della flag finale.

1. Introduzione e Ricognizione Iniziale

Il mio percorso di penetration testing è iniziato esplorando l'ambiente web esposto dal target. Puntando il browser sull'indirizzo IP della macchina, ho scoperto un blog WordPress deprecato (versione 4.5), situato all'interno di una cartella di backup.

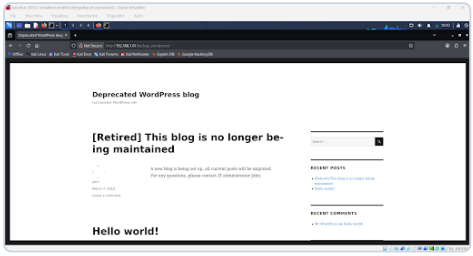


Figura 1: Esplorazione iniziale del blog WordPress deprecato nel browser.

Per mappare la struttura del server e individuare possibili punti di accesso o risorse nascoste, ho avviato una scansione delle directory utilizzando Gobuster con una wordlist standard.

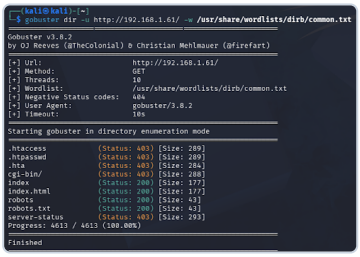


Figura 2: Analisi delle directory e dei file esposti sul server web.

2. Analisi e Sfruttamento di WordPress

Verificata la versione in esecuzione (WordPress 4.5), ho utilizzato Searchsploit per individuare le vulnerabilità associate, trovando diversi vettori sfruttabili.



Figura 3: Ricerca di exploit specifici per WordPress 4.5 tramite Searchsploit.

Tramite le credenziali individuate nei file di configurazione, sono riuscito ad accedere al pannello di amministrazione del CMS.

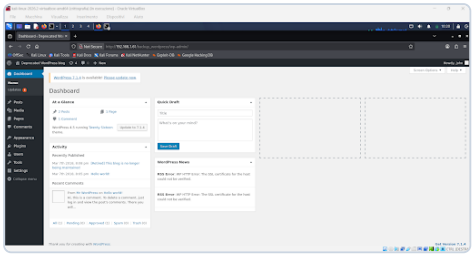


Figura 4: Accesso con successo alla dashboard di amministrazione di WordPress.

3. Iniezione della Web Shell

Per interagire direttamente con il filesystem del server, ho modificato il file del tema (`footer.php`) inserendo una web shell PHP personalizzata, verificandone il corretto funzionamento.

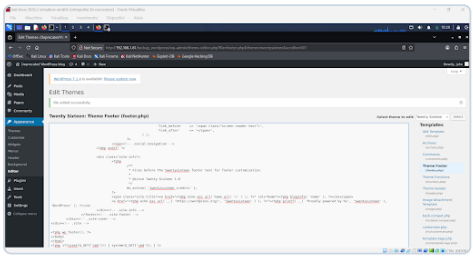


Figura 5: Inserimento della web shell all'interno del tema attivo di WordPress.

4. Scalata dei Privilegi (Privilege Escalation)

Ottenuto l'accesso iniziale come utente `www-data`, ho esaminato il sistema identificando un task di pulizia pianificato (`/usr/local/bin/cleanup`) eseguito da root ogni minuto con permessi globali di scrittura. Modificando questo script per impostare il bit SUID su `/bin/bash`, ho atteso l'esecuzione automatica del cronjob.

Infine, eseguendo il comando `bash -p`, ho elevato con successo i privilegi a **root**, confermando l'identità tramite `whoami` e leggendo la flag finale.

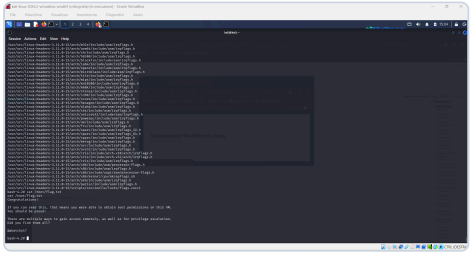


Figura 6: Visualizzazione della flag di successo e completamento della CTF.